

Project Report Week 08
IT-SIMPLERA | RED TEAM
Secure the Range: End-to-End Cybersecurity Assessment



Submitted By:

- 1. M. Abdullah**
- 2. M. Azeem**
- 3. Kashaf Arshad**

Role:

Cyber Security Analyst (Intern)

Submitted to:

Talal Rehan (Instructor)

IT-SIMPLERA Institute

Ethics Notice: All scanning and testing referenced in this report was performed exclusively against an instructor-approved lab target. No unauthorized systems were accessed.

Project Overview

You have been hired as a Junior Security Analyst by a fictional company, "Nimbus Retail Co.", which is preparing to launch a new e-commerce platform. Before going live, management wants an independent security review of their planned infrastructure. Your job is to simulate the full lifecycle of a security assessment — from understanding core concepts, to mapping the network, to reconnaissance, scanning, and finally producing a professional vulnerability assessment report with remediation guidance. This project consolidates the concepts covered across the internship program and introduces a few new areas that a working analyst is expected to know, including cryptography basics, web application security, and incident response.

Phase 1 Foundations & Network Design

Q1. Real-World Cybersecurity Breaches and CIA Triad

Objective

To analyze three real-world cybersecurity breaches and identify which element of the CIA Triad (Confidentiality, Integrity, or Availability) was violated in each incident, with a brief explanation of the impact.

1. AssuranceAmerica Data Breach 2026

CIA Triad Violation: Confidentiality

The AssuranceAmerica data breach exposed sensitive personal information, including driver's license numbers belonging to millions of individuals. The attackers gained unauthorized access to the company's systems and obtained private customer information. This incident represents a violation of **Confidentiality** because sensitive information was accessed by unauthorized individuals.

2. Ernst & Young (EY) Data Breach 2026

CIA Triad Violation: Confidentiality

Ernst & Young experienced a security incident involving unauthorized access through a third-party IT support platform. Sensitive client documents, including tax and financial information, were accessed during the incident. This represents a violation of **Confidentiality** because private client information was exposed to unauthorized individuals.

3. Craneware Data Breach 2026

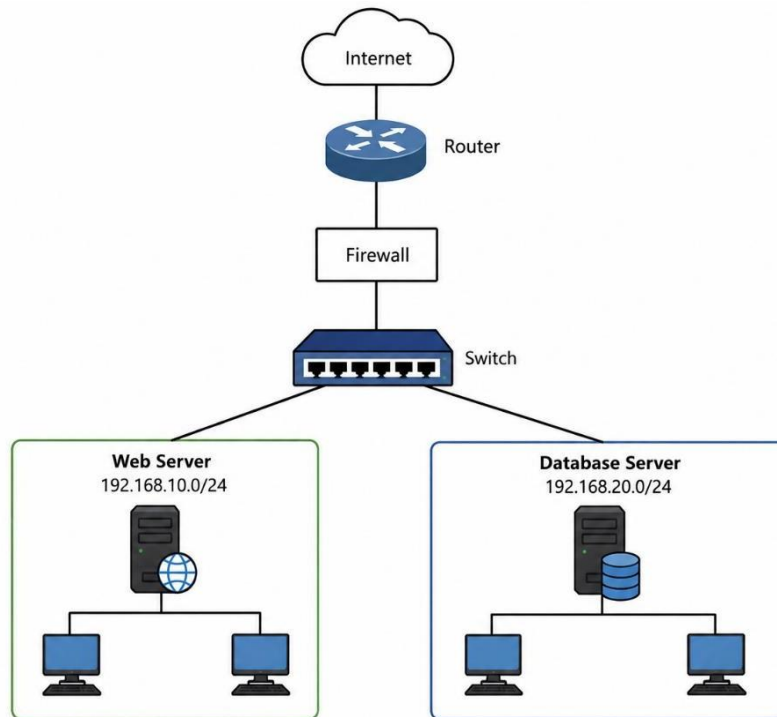
CIA Triad Violation: Confidentiality

Craneware reported a cyberattack in which unauthorized individuals accessed and exfiltrated data from its corporate systems. The affected information included employee data and portions of customer and partner records. This incident violated **Confidentiality** because sensitive organizational and personal information was accessed and taken without authorization.

Q2. Network Diagram for Nimbus Retail -Co

Objective

To design a secure small-office network for Nimbus Retail Co. using network segmentation, a router, firewall, switch, web server, and database server. The design aims to separate network resources into different subnets and control communication between them.



Segmentation Choices

- **Web Server Subnet: 192.168.10.0/24:** The web server is placed in a separate subnet to isolate it from the database server and other internal resources.
- **Database Server Subnet: 192.168.20.0/24:** The database server is kept in a separate subnet to protect sensitive customer and business data.
- **Firewall:** The firewall controls traffic between the Internet and internal networks and helps restrict unauthorized access.
- **Network Segmentation:** Separating the web and database servers limits the impact of a security incident and prevents direct access to the database from outside the network.

Q3. Tracing “Buy Now” Through the 7 OSI Layers

When a customer clicks “**Buy Now**” on the website, the request passes through all seven layers of the OSI model. The process can be traced from the Physical Layer (Layer 1) upward and then back down through the network.

Objective:

To trace a customer's “**Buy Now**” action through all seven layers of the OSI model and understand the role of each layer in transmitting the request from the customer’s device to the web server.

Layer 1: Physical Layer

What happens: The data is transmitted as electrical, radio, or optical signals through the physical network medium.

Layer 2: Data Link Layer

What happens: The device uses MAC addresses and frames to deliver the data across the local network. The switch forwards the frame to the appropriate device.

Layer 3: Network Layer

What happens: IP addresses are used to identify the source and destination. Routers determine the path for the data to reach the web server.

Layer 4: Transport Layer

What happens: TCP provides reliable delivery of the request and ensures that the data reaches the correct application using port numbers.

Layer 5: Session Layer

What happens: The session between the customer's device and the web server is established and managed so that communication can continue properly.

Layer 6: Presentation Layer

What happens: Data is formatted and, when applicable, encrypted or decrypted so that the communicating systems can understand it securely.

Layer 7: Application Layer

What happens: The customer's web browser sends the “**Buy Now**” request to the website. The web application receives the request and processes the customer's purchase.

OSI Layer Order

7 → Application Layer

6 → Presentation Layer

5 → Session Layer

4 → Transport Layer

3 → Network Layer

2 → Data Link Layer

1 → Physical Layer

Q4. Access control policy for Nimbus Retail Co.

Purpose

This policy defines how Nimbus Retail Co. grants, reviews, and revokes access to company systems and data, ensuring every employee and service account holds only the access required to perform its function (least privilege).

Access Principles

- **Default deny:** new accounts start with no access; permissions are added explicitly by role, never removed from a broad default.
- **Role-based access control (RBAC):** access is granted by job function (e.g., "Web Support", "Database Admin", "Customer Service"), not to individuals ad hoc.
- **Separation of duties:** no single account can either approve and process financial transactions or deploy code to production without a second reviewer.
- **Time-bound elevation:** administrative/root access is granted just-in-time for a specific task and expires automatically rather than standing permanently.

Role	Access Granted
Web Administrator	Access to manage and maintain the web server; no direct access to the database server.
Database Administrator	Access to manage the database server and database records; no access to unnecessary web-server administration.
Customer Service Representative	Read-only access to order status and shipping information; no access to payment card data or database administration.
IT Security Analyst	Access to security logs, monitoring tools, and security systems required for security-related tasks.

Phase :02 Reconnaissance & OSINT

Introduction

This report about Reconnaissance and Open Source Intelligence (OSINT) gathering against the authorized lab target, indrive.com, operated by SUOL Innovations Ltd. indrive.com was selected because it runs a public bug bounty program on **HackerOne** (hackerone.com/indrive), which explicitly authorizes passive reconnaissance and vulnerability research within its defined scope.

Q5 — OSINT Findings on the Lab Target Domain

OSINT techniques — WHOIS lookups, certificate inspection, passive technology fingerprinting, and Google Dorking — were used to build a public profile of indrive.com without touching the live application. Eight findings are documented below, each supported by evidence captured during the assessment.

Finding 1 — Registrant Organization & Bug Bounty Authorization

WHOIS records identify SUOL Innovations Ltd., based in Nicosia, Cyprus, as the registrant organization behind indrive.com, the corporate domain of the **inDrive** ride-hailing, delivery, and freight platform. The organization operates a public bug bounty program at hackerone.com/indrive, which formally authorizes reconnaissance and testing within its defined scope.

Finding 2 — Domain Registration Details

The domain is registered through CSC Corporate Domains, Inc. (IANA ID 299), was created on 1998-04-08, and is set to expire on 2027-04-07, with a clientTransferProhibited status and unsigned DNSSEC.

WHOIS search results

Domain Information

Name	INDRIVE.COM
Registry Domain ID	5342839_DOMAIN_COM-VRSN
Registered On	1998-04-08T04:00:00Z
Expires On	2027-04-07T04:00:00Z
Updated On	2026-04-03T05:05:14Z
Domain Status	client transfer prohibited
Name Servers	NS-1301.AWSDNS-34.ORG NS-1831.AWSDNS-36.CO.UK NS-389.AWSDNS-48.COM NS-694.AWSDNS-22.NET

Find your Domain

indrivepk.com

Rs1 ~~Rs4,999~~

1st yr only with 3 yr term

insdrive.com

Rs1 ~~Rs4,999~~

1st yr only with 3 yr term

indriveco.com

Contact

Registrant Contact

Name	-
Organization	SUOL INNOVATIONS LTD
Phone	-
Fax	-
Email	https://domaincontact.cscglobal.com/contactholder/indrive.com/registrant
Mailing Address	Nicosia

Registrar Information

Name	CSC Corporate Domains, Inc.
IANA ID	299
Abuse Contact Email	domainabuse@cscglobal.com
Abuse Contact Phone	tel:+1.888.780.2723

Take a look at these alternate options

indrivepk.com	Rs1 Rs4,999 1st yr only with 3 yr term ⓘ	
insdrive.com	Rs1 Rs4,999 1st yr only with 3 yr term ⓘ	
indriveco.com	Rs1 Rs4,999 1st yr only with 3 yr term ⓘ	
indrive.ai	Rs14,050 Rs44,967 1st yr only with 2 yr term ⓘ	

PREMIUM ⓘ

Contact Us

Finding 3 — Hosting Provider & IP Ownership (ASN)

The A records for indrive.com resolve to Amazon CloudFront IP space (ASN AS16509, AMAZON-02). An ARIN WHOIS/RDAP lookup on a resolved address (3.162.140.5) confirms the block sits within the 3.160.0.0/14 (AMAZON-CF) netblock, itself part of the parent allocation 3.128.0.0/9 (AT-88-Z, Amazon Technologies Inc.).

```

kali@windrow: ~
$ whois 3.162.140.5

#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2025, American Registry for Internet Numbers, Ltd.
#

# start

NetRange: 3.128.0.0 - 3.255.255.255
CIDR: 3.128.0.0/9
NetName: AT-88-Z
NetHandle: NET-3-128-0-0-1
Parent: NET3 (NET-3-0-0-0-0)
NetType: Direct Allocation
OriginAS:
Organization: Amazon Technologies Inc. (AT-88-Z)
RegDate: 2018-06-25
Updated: 2018-09-13
Ref: https://rdap.arin.net/registry/ip/3.128.0.0

OrgName: Amazon Technologies Inc.
OrgId: AT-88-Z
Address: 410 Terry Ave N.
City: Seattle
StateProv: WA
PostalCode: 98109
Country: US
RegDate: 2011-12-08
Updated: 2016-06-17
Comment: All abuse reports MUST include:
Comment: * src IP

```

```
# start
NetRange:      3.160.0.0 - 3.163.255.255
CIDR:          3.160.0.0/14
NetName:       AMAZON-CF
NetHandle:     NET-3-160-0-1
Parent:        AT-88-Z (NET-3-128-0-0-1)
NetType:       Reallocated
OriginAS:      Amazon.com, Inc. (AMAZON-4)
Organization:  Amazon.com, Inc. (AMAZON-4)
RegDate:       2022-12-09
Updated:       2022-12-09
Ref:           https://rdap.arin.net/registry/ip/3.160.0.0

OrgName:       Amazon.com, Inc.
OrgId:         AMAZON-4
Address:       1918 8th Ave
City:          SEATTLE
StateProv:     WA
PostalCode:    98101-1244
Country:       US
RegDate:       1995-01-23
Updated:       2022-09-30
Ref:           https://rdap.arin.net/registry/entity/AMAZON-4

OrgRoutingHandle: IPROU3-ARIN
OrgRoutingName:   IP Routing
OrgRoutingPhone:  +1-206-555-0000
OrgRoutingEmail:  aws-routing-poc@amazon.com
OrgRoutingRef:    https://rdap.arin.net/registry/entity/IPROU3-ARIN

OrgRoutingHandle: ARMP-ARIN
OrgRoutingName:   AWS RPKI Management POC
OrgRoutingPhone:  +1-206-555-0000
OrgRoutingEmail:  aws-rpki-routing-poc@amazon.com
OrgRoutingRef:    https://rdap.arin.net/registry/entity/ARMP-ARIN

OrgAbuseHandle:  AEA8-ARIN
OrgAbuseName:    Amazon EC2 Abuse
OrgAbusePhone:   +1-206-555-0000
OrgAbuseEmail:   trustandsafety@support.aws.com
OrgAbuseRef:     https://rdap.arin.net/registry/entity/AEA8-ARIN

OrgNOCHandle:   AANO1-ARIN
OrgNOCName:     Amazon AWS Network Operations
```

Finding 4 — Nameservers

indrive.com is delegated to four AWS Route 53 nameservers, confirming that DNS management is hosted on AWS infrastructure: ns-1301.awsdns-34.org, ns-1831.awsdns-36.co.uk, ns-389.awsdns-48.com, and ns-694.awsdns-22.net.

Finding 5 — SSL / Certificate Transparency Information

The certificate presented for indrive.com is a wildcard certificate (*.indrive.com) issued by Amazon RSA 2048 M01, valid from 28 April 2026 to 12 November 2026, chaining to Amazon Trust Services (AWS Certificate Manager). Wildcard certificates and their issuance history are also visible through public certificate-transparency logs (e.g., crt.sh), which independently corroborate this issuance and reveal historical certificate activity for the domain.

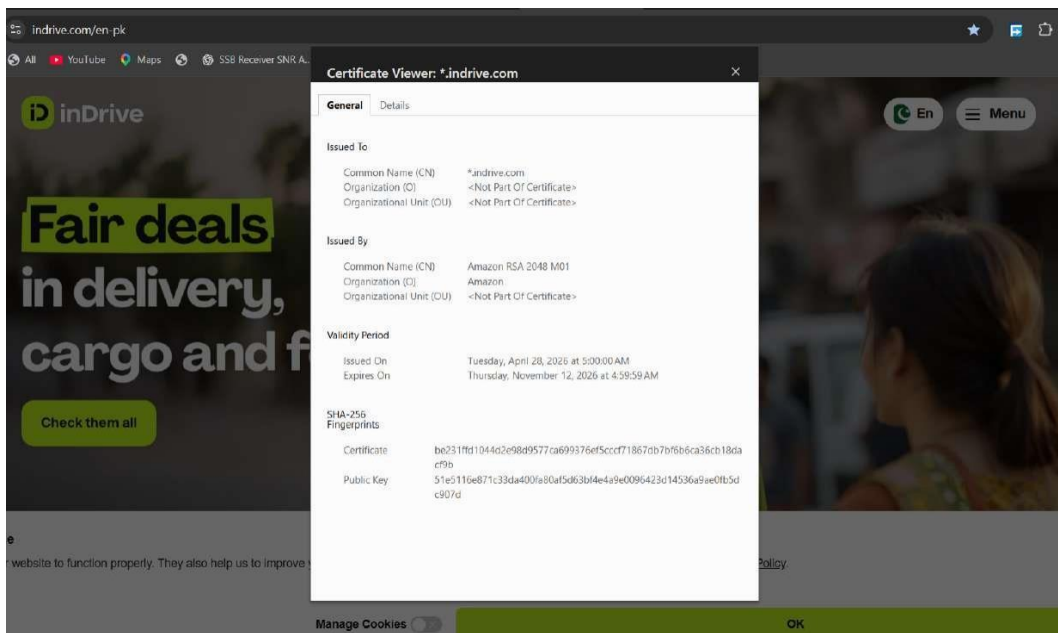
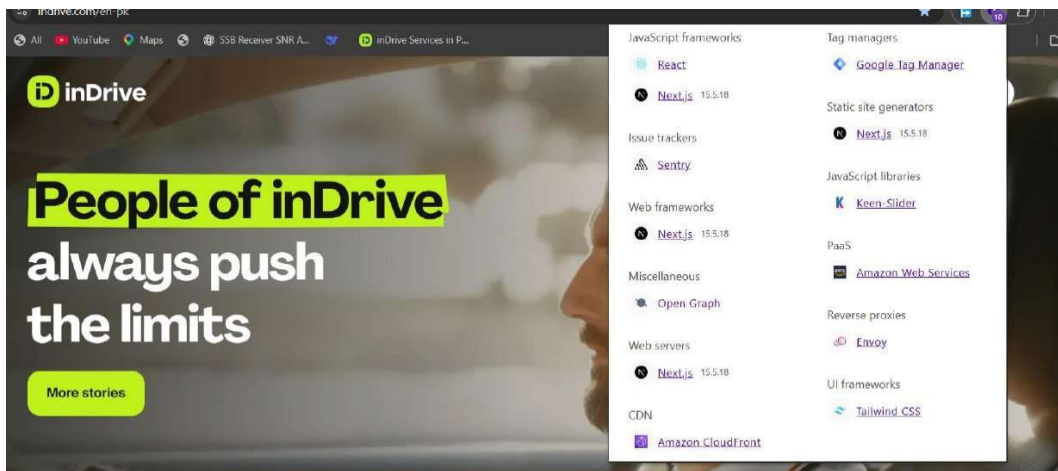


Figure 5.5 — Browser certificate viewer for indrive.com, showing a wildcard *.indrive.com certificate issued by Amazon RSA 2048 M01.

Finding 6 — Technology Stack (Passive Fingerprinting)

Passive fingerprinting with Wappalyzer and browser DevTools identified a React / Next.js 15.5.18 front end, Envoy reverse proxy in front of an Istio service mesh, Tailwind CSS, Google Tag Manager, Sentry error tracking, and Amazon CloudFront / AWS as the hosting and CDN layer.



Wappalyzer technology profile for indrive.com.

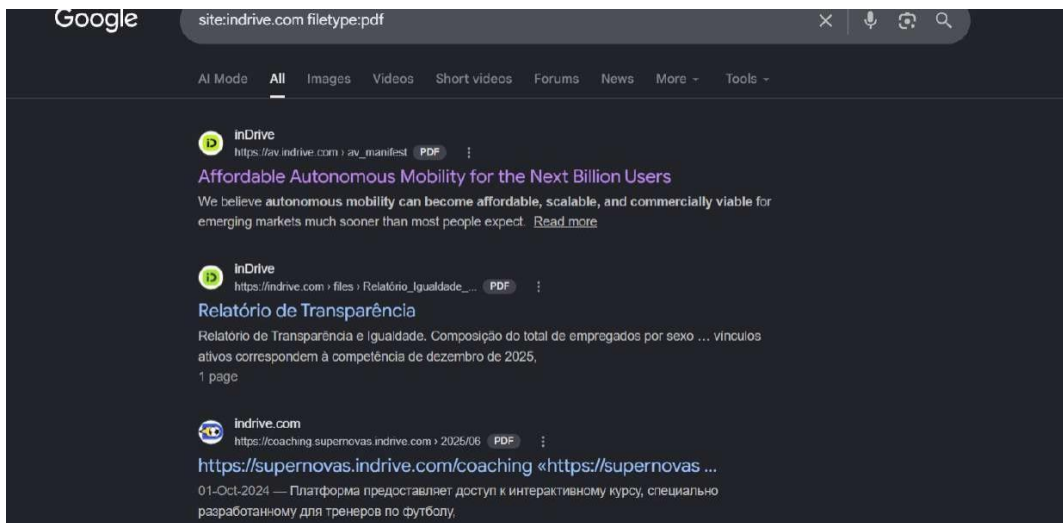
Finding 7 — Email Security Posture (SPF)

The domain's TXT records include an SPF record authorizing Google Workspace, Amazon SES, Mandrill, and Salesforce Marketing Cloud (zcsend.net) as legitimate senders, terminating with a hard-fail (-all) policy. No DKIM or DMARC selector records were observed in the captured TXT data, which is flagged as a residual phishing/spoofing exposure worth verifying separately.

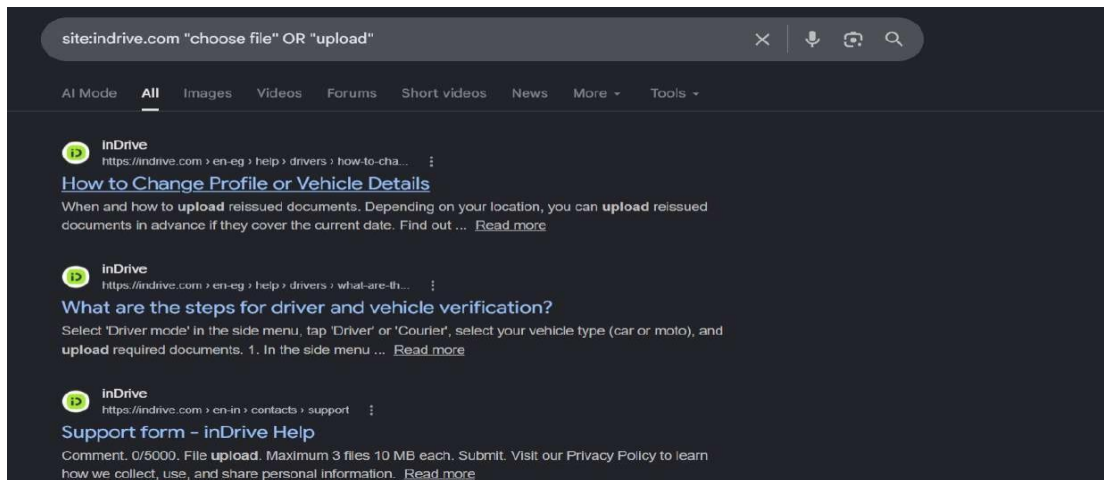
Finding 8 — Google Dork Investigation

Twenty Google Dork queries were run against indrive.com to probe for publicly indexed documents, login/API surfaces, and unintentionally exposed files. The four most notable results were screenshots as evidence:

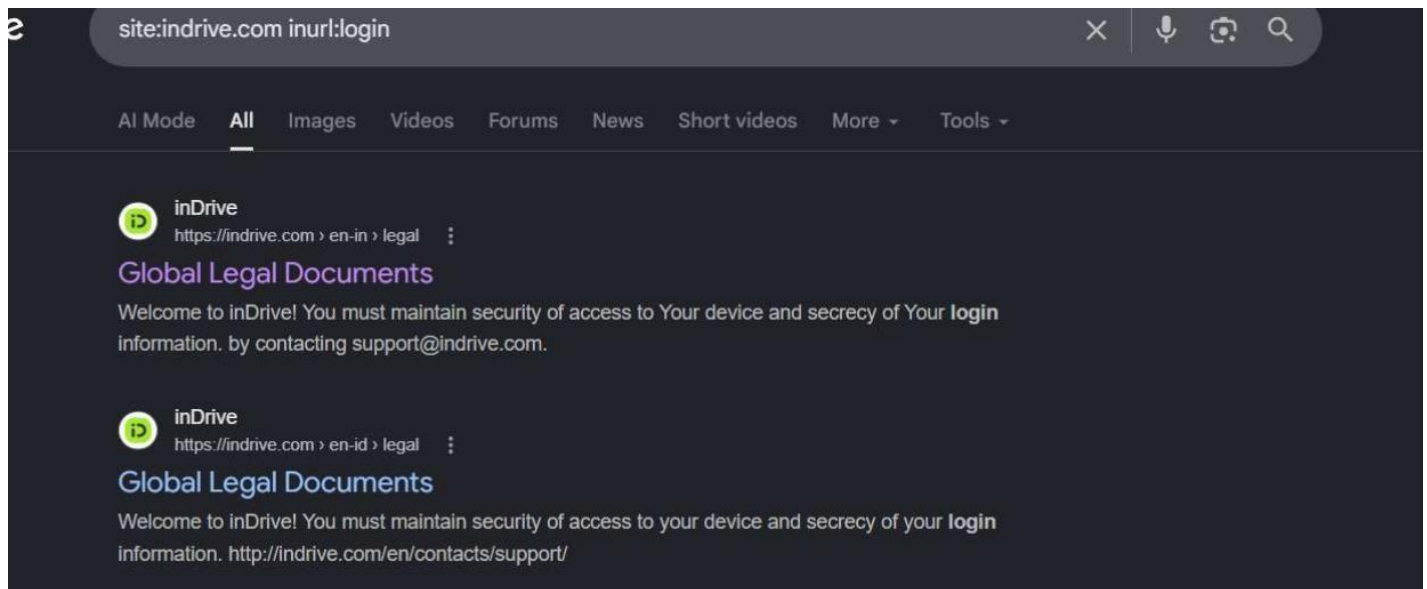
- **Dork 1** — Publicly indexed PDF documents were returned by `site:indrive.com filetype:pdf`.
- **Dork 2** — Driver document-upload help pages surfaced via `site:indrive.com "choose file" OR "upload"`.
- **Dork 3** — Legal/login-related pages were returned by `site:indrive.com inurl:login`.
- **Dork 4** — The public URL-checker internal tool was surfaced by `site:indrive.com inurl:api`.



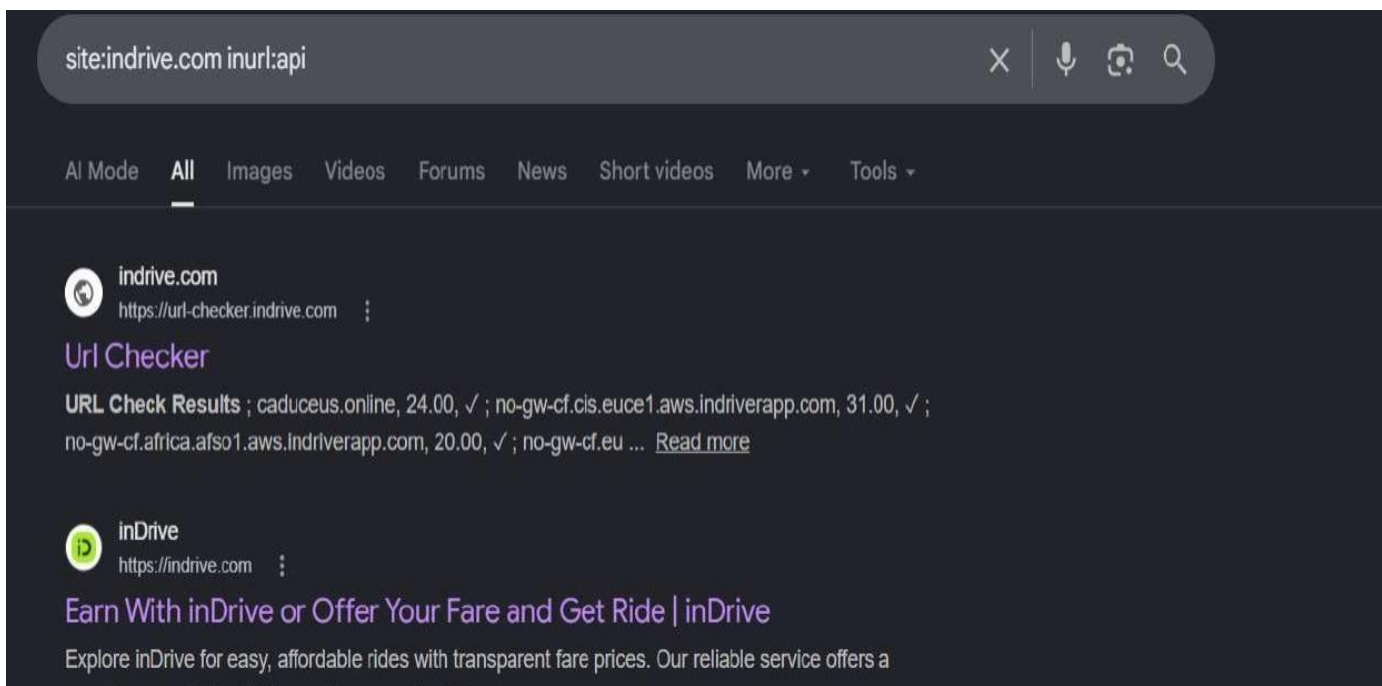
site:indrive.com filetype:pdf, showing publicly indexed PDF documents.



site:indrive.com "choose file" OR "upload", showing driver document-upload help pages.



site:indrive.com inurl:login, showing legal/login-related pages.



site:indrive.com inurl:api, showing the public URL-checker tool.

Q6 — Subdomain Enumeration

Subdomain enumeration was performed using three independent open-source tools — Assetfinder, OWASP Amass, and Subfinder — each drawing on different public data sources (certificate transparency logs, passive DNS, search engines, and third-party APIs). Running multiple tools maximizes coverage, since no single source is complete. Terminal output for each tool is captured below.

```
(kali@window)-[~]
$ assetfinder --subs-only indrive.com > assetfinder_subs.txt

(kali@window)-[~]
$ ls
42745.py      Android-Phone-Radar-Gun  assetfinder_subs.txt  CC-attack  data      Downloads  key.pem  nextsurf  pentest_lab  Public  Templates  top12m.txt  Y
Ammyth       AndroidRAT              Auto_for_IP_changer  cert.pem   Desktop  hashes.txt  login.html  nuclei-templates  phoneinfo  sandi.jpg  test.php  users.txt
AllHacking   Anonymous-SMS           BlllCIPHER           cookies.txt  dnsenum  hashes.txt.save.1  Music     passwords.txt  Pictures  stonker.py.save  testscan.html  venv
amass-subs.txt  a.out                  DarkComet-RAT-S.3.1  Documents  hydra.restore  myonv      pthn.py  stormbreaker  testscan.xml  Videos
```

```
(kali@window)-[~]
$ cat assetfinder_subs.txt
indrive.com
analytics.indrive.com
arsentomsky.indrive.com
av.indrive.com
beginit.indrive.com
www.beginit.indrive.com
blog.indrive.com
book.indrive.com
bus.br.indrive.com
brand.indrive.com
carvers.indrive.com
cargo.indrive.com
company.indrive.com
compliance.indrive.com
couriers.indrive.com
cr.indrive.com
delivery-webview.indrive.com
demo.indrive.com
fairchoice.indrive.com
www.fairchoice.indrive.com
gentecondrive.indrive.com
greenseat.indrive.com
handbook.indrive.com
id.indrive.com
impact-together.indrive.com
infaces.indrive.com
intercity.indrive.com
user-identification.invision.indrive.com
jlml.indrive.com
```

assetfinder --subs-only indrive.com > assetfinder_subs.txt.

```
greenseat.indrive.com
handbook.indrive.com
id.indrive.com
impact-together.indrive.com
infaces.indrive.com
intercity.indrive.com
user-identification.invision.indrive.com
jlml.indrive.com
jlml-wf.indrive.com
www.jlml.indrive.com
job.indrive.com
media.indrive.com
money.indrive.com
movie.indrive.com
bus.mx.indrive.com
promotion.indrive.com
pvz.indrive.com
services.indrive.com
sgtm.indrive.com
share.indrive.com
sharetrip.indrive.com
sparklab.indrive.com
supernovas.indrive.com
coaching.supernovas.indrive.com
www.supernovas.indrive.com
trustgame.indrive.com
www.trustgame.indrive.com
updrive.indrive.com
url-checker.indrive.com
us.indrive.com
pristegnimechty.indrive.com
www.pvz.indrive.com
```

assetfinder output (continued) — subdomain list.

```
(kali@window)-[~]
$ amass enum -d indrive.com -o amass_subs.txt

indrive.com (FQDN) → ns_record → ns-1301.awsdns-34.org (FQDN)
indrive.com (FQDN) → ns_record → ns-1831.awsdns-36.co.uk (FQDN)
indrive.com (FQDN) → ns_record → ns-389.awsdns-48.com (FQDN)
indrive.com (FQDN) → ns_record → ns-694.awsdns-22.net (FQDN)
indrive.com (FQDN) → mx_record → alt2.aspmx.l.google.com (FQDN)
indrive.com (FQDN) → mx_record → alt1.aspmx.l.google.com (FQDN)
indrive.com (FQDN) → mx_record → alt4.aspmx.l.google.com (FQDN)
indrive.com (FQDN) → mx_record → aspmx.l.google.com (FQDN)
arsentomsky.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
emploio.indrive.com (FQDN) → cname_record → d2jigylp22sfu.cloudfront.net (FQDN)
demo.indrive.com (FQDN) → cname_record → indrive-fl.web.app (FQDN)
promotion.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
supernovas.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
yourpace.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
injob.indrive.com (FQDN) → cname_record → d2jigylp22sfu.cloudfront.net (FQDN)
rabota.indrive.com (FQDN) → cname_record → d2jigylp22sfu.cloudfront.net (FQDN)
ventures.indrive.com (FQDN) → cname_record → d2jigylp22sfu.cloudfront.net (FQDN)
gentecondrive.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
www.beginit.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
greenseat.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
pristegnimechty.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
indrive.com (FQDN) → mx_record → alt3.aspmx.l.google.com (FQDN)
beginit.indrive.com (FQDN) → ns_record → journey.ns.cloudflare.com (FQDN)
beginit.indrive.com (FQDN) → ns_record → lamar.ns.cloudflare.com (FQDN)
beginit.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
handbook.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
intercity.indrive.com (FQDN) → a_record → 13.224.236.9 (IPAddress)
intercity.indrive.com (FQDN) → a_record → 13.224.236.63 (IPAddress)
intercity.indrive.com (FQDN) → a_record → 13.224.236.104 (IPAddress)
intercity.indrive.com (FQDN) → a_record → 13.224.236.19 (IPAddress)
money.indrive.com (FQDN) → a_record → 3.165.75.107 (IPAddress)
money.indrive.com (FQDN) → a_record → 3.165.75.95 (IPAddress)
money.indrive.com (FQDN) → a_record → 3.165.75.29 (IPAddress)
money.indrive.com (FQDN) → a_record → 3.165.75.96 (IPAddress)
fairchoice.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
impact-together.indrive.com (FQDN) → cname_record → cdn.webflow.com (FQDN)
inlab.indrive.com (FQDN) → cname_record → c-bea2fc7136157f9e24f19df139c7f93b.frontify.com (FQDN)
16589 (ASN) → announced_by → AMAZON-02 - Amazon.com, Inc. (RIROrganization)
16589 (ASN) → announced_by → 13.224.236.0/24 (Netblock)
cdn.webflow.com (FQDN) → a_record → 198.202.211.1 (IPAddress)
cdn.webflow.com (FQDN) → aaaa_record → 2620:cb:2000::1 (IPAddress)
d2jigylp22sfu.cloudfront.net (FQDN) → a_record → 13.224.236.26 (IPAddress)
d2jigylp22sfu.cloudfront.net (FQDN) → a_record → 13.224.236.97 (IPAddress)
```

amass enum -d indrive.com -o amass_subs.txt, showing DNS relationships (CNAME/A/MX) discovered during enumeration.

```
(kali@window)-[~]
$ subfinder -d indrive.com -o subfinder_subs.txt

projectdiscovery.io

[INF] Current subfinder version v2.14.0 (latest)
[INF] Loading provider config from /home/kali/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for indrive.com
inapps.indrive.com
wildcard.internal.dev.delivery.indrive.com
fr.indrive.com
injob.indrive.com
money.indrive.com
pvz.indrive.com
compliance.indrive.com
web.indrive.com
dxy.indrive.com
inlab.indrive.com
rabota.indrive.com
url-checker.indrive.com
wildcard.delivery.indrive.com
www.catalogue.indrive.com
analytics.indrive.com
brand.indrive.com
sale.indrive.com
ns2.indrive.com
av.indrive.com
company.indrive.com
qa.delivery.indrive.com
handbook.indrive.com
landing.indrive.com
sgtm.indrive.com
fairchoice.indrive.com
food.indrive.com
id.indrive.com
user-identification.invision.indrive.com
s.indrive.com
hostmaster.indrive.com
couriers.indrive.com
sandbox.delivery.indrive.com
```

subfinder -d indrive.com -o subfinder_subs.txt.

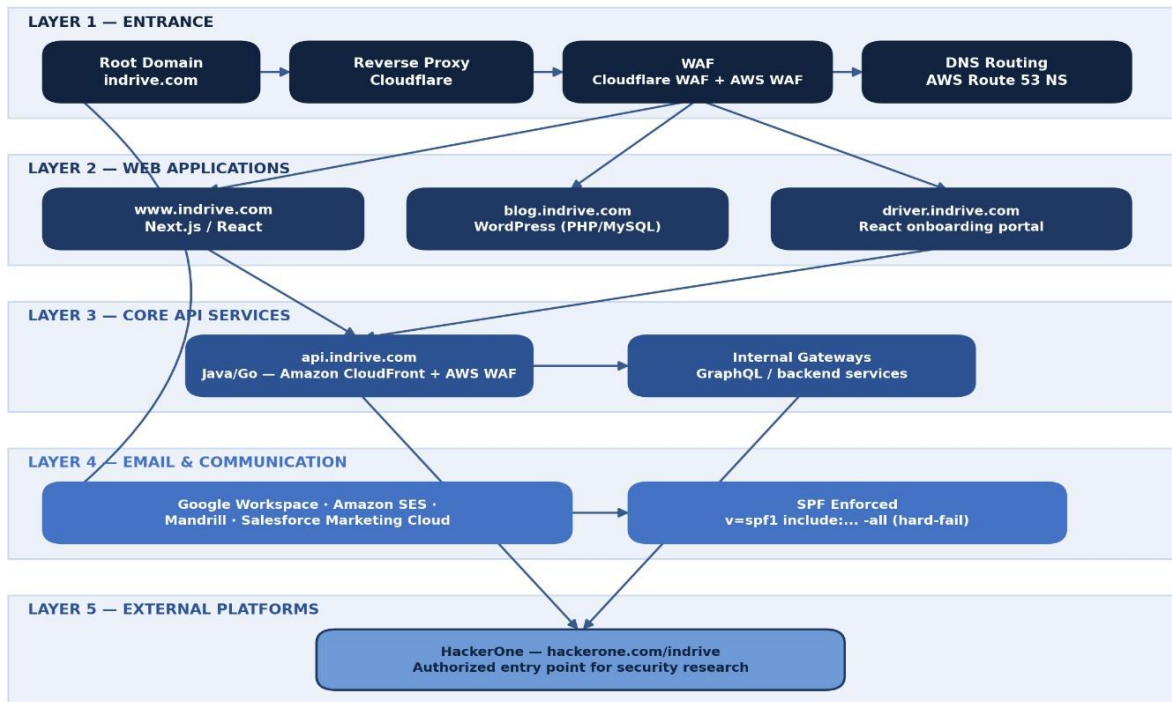
Merged & Deduplicated Results

After merging and deduplicating the three tool outputs, over 70 unique indrive.com subdomains were identified — well above the required minimum of ten. A representative selection of at least ten is listed below, with a brief note on why each is security-relevant; the full inventory of 70+ assets was used to build the attack-surface diagram in Q7.

Subdomain	Category / Security Relevance
api.indrive.com	Primary API gateway — highest-value target; any misconfiguration exposes user/driver data.
id.indrive.com	Likely central identity/login endpoint — high-value target for account-related testing.
money.indrive.com	Payments/earnings-related subdomain — high sensitivity, handles financial data.
s.indrive.com	Returns HTTP 401 from AmazonS3 — indicates an S3-backed asset; bucket policy should be reviewed.
qa.delivery.indrive.com	QA/staging environment — often has debug features and weaker hardening.
sandbox.delivery.indrive.com	Sandbox environment — frequently reuses production data/logic and is less monitored.
wildcard.internal.dev.delivery.indrive.com	Explicitly named 'internal.dev' — signals a non-production environment.
url-checker.indrive.com	Custom internal utility exposed publicly; may leak infrastructure hostnames.
sgtm.indrive.com	Server-side Google Tag Manager endpoint — misconfiguration can allow SSRF via tag definitions.
blog.indrive.com	WordPress-based blog (PHP/MySQL) — frequent target for outdated plugin/theme vulnerabilities.
careers.indrive.com	Careers portal (Apache/Ubuntu) — often integrates with third-party ATS systems.
user-identification.invision.indrive.com	Identity-verification (KYC/driver ID) service — handles sensitive PII.

Q7 — Attack Surface Diagram

A layered attack-surface diagram was produced to summarize the reconnaissance findings from Q5 and Q6, showing all discovered assets and how they relate to one another: the entrance layer (DNS/CDN/WAF), front-end web applications, core API/backend services, email/communication infrastructure, and the external bug bounty program that formally authorizes security research against the estate.

indrive.com — Digital Attack Surface Map*Layered view of assets discovered during passive reconnaissance (Q5-Q7)***Layer Summary**

Layer	Components
Layer 1 — Entrance	Root domain (indrive.com), Cloudflare reverse proxy, Cloudflare WAF + AWS WAF, AWS Route 53 nameservers.
Layer 2 — Web Applications	www.indrive.com (Next.js/React), blog.indrive.com (WordPress), driver.indrive.com (React onboarding).
Layer 3 — Core API Services	api.indrive.com (Java/Go, Amazon AWS/CloudFront) fronting internal backend gateways.
Layer 4 — Email & Communication	Google Workspace, Amazon SES, Mandrill, Salesforce — all authorized via SPF (v=spf1 ... -all).
Layer 5 — External Platforms	hackerone.com/indrive — the authorized entry point for external security researchers.

Phase 3 Enumeration & Scanning

Q8. Nmap Scan Comparison

Objective

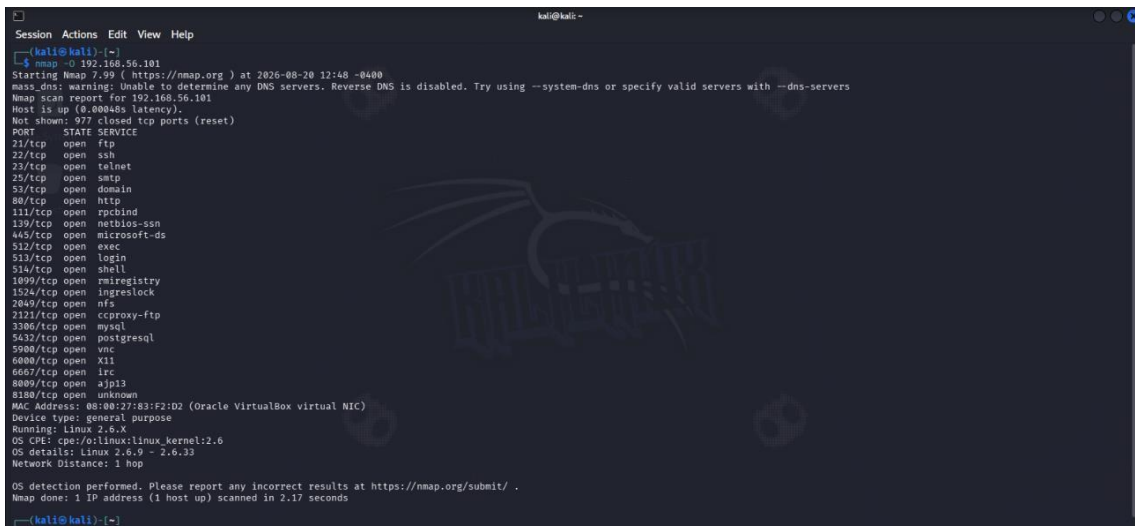
The objective of this task was to perform different types of Nmap scans against the assigned lab target and compare their results in terms of speed and level of information obtained.

Target IP: 192.168.56.101

1. Nmap OS Detection Scan

Command:

`nmap -O 192.168.56.101`



```
Session Actions Edit View Help
kali@kali: ~
kali@kali:~$ nmap -O 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 12:48 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
57/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  tcp-proxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8080/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:83:F2:02 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.x
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.17 seconds
kali@kali:~$
```

Result:

The scan identified the target as a Linux-based system. The detected operating system details were **Linux 2.6.x**, with the OS range estimated as **Linux 2.6.9 – 2.6.33**.

2. Nmap Service Version Detection Scan

Command:

`nmap -sV 192.168.56.101`

```
kali@kali: ~
Session Actions Edit View Help
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.17 seconds

(kali@kali)~$ nmap -sV 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 12:52 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.00013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:83:F2:D2 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.94 seconds

(kali@kali)~$
```

Result:

This scan identified the services running on the open ports along with their versions. Some examples included **vsftpd 2.3.4**, **OpenSSH 4.7p1**, **Apache HTTP Server 2.2.8**, **Samba 3.X-4.X**, **MySQL 5.0.51a**, **PostgreSQL 8.3.x**, and **Apache Tomcat**.

3. Nmap SYN Scan

Command: `nmap -sS 192.168.56.101`

```
(kali@kali)~$ nmap -sS 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 13:05 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.00015s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  x11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:83:F2:D2 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.26 seconds

(kali@kali)~$
```

Result:

The SYN scan identified multiple open TCP ports on the target. These included ports such as **21, 22, 23, 25, 53, 80, 139, 445, 3306, 5432, 5900, 6667, 8009, and 8180.**

4. Nmap Aggressive Scan

Command:

nmap -A 192.168.56.101

```
kali@kali:~$ nmap -A 192.168.56.101
Starting Nmap 7.99 (https://nmap.org) at 2020-08-29 13:18 -0400
Host discovery timing: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers.
Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http

Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http

Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http
```

```
Applications
kali@kali:~$ nmap -A 192.168.56.101
Starting Nmap 7.99 (https://nmap.org) at 2020-08-29 13:18 -0400
Host discovery timing: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers.
Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http

Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http
```

```
kali@kali:~$ nmap -A 192.168.56.101
Starting Nmap 7.99 (https://nmap.org) at 2020-08-29 13:18 -0400
Host discovery timing: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers.
Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http

Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http
```

```
kali@kali:~$ nmap -A 192.168.56.101
Starting Nmap 7.99 (https://nmap.org) at 2020-08-29 13:18 -0400
Host discovery timing: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers.
Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http

Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http
```

```
kali@kali:~$ nmap -A 192.168.56.101
Starting Nmap 7.99 (https://nmap.org) at 2020-08-29 13:18 -0400
Host discovery timing: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers.
Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http

Nmap scan report for 192.168.56.101
Host is up (0.0000s latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  dns
80/tcp    open  http
139/tcp   open  smb
445/tcp   open  smb
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  http
6667/tcp  open  irc
8009/tcp  open  http
8180/tcp  open  http
```

Result:

The aggressive scan provided the most detailed information. In addition to open ports and service versions, it provided **OS detection, service information, host script results, SMB information, FTP information, SSL details, and traceroute information.**

Comparison Table

Scan Type	Command	Main Information Found	Detail Level	Time
OS Detection	nmap -O 192.168.56.101	Operating system details	Medium	1.70 sec
Service Version Detection	nmap -sV 192.168.56.101	Services + exact versions	High	11.88 sec
SYN Scan	nmap -sS 192.168.56.101	Open TCP ports	Basic	0.25 sec
Aggressive Scan	nmap -A 192.168.56.101	Ports, services, versions, OS, scripts, SMB, SSL, traceroute	Highest	22.89 sec

Conclusion

The SYN scan (-sS) was the fastest among the four scans, while the Aggressive scan (-A) provided the most detailed information. The -sV scan was particularly useful for identifying the exact versions of running services, whereas the -O scan focused mainly on operating-system detection.

Q9. Open Ports, Services and Versions

Nmap Service Version Detection

The target system 192.168.56.101 was scanned using Nmap service version detection:

nmap -sV 192.168.56.101

The scan identified the following open ports, services, and versions:

Port	Service	Version
21/tcp	FTP	vsftpd 2.3.4
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1

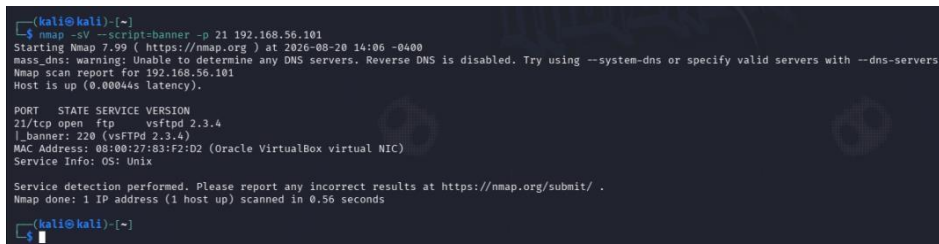
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix smtpd
53/tcp	DNS	ISC BIND 9.4.2
80/tcp	HTTP	Apache httpd 2.2.8
111/tcp	RPCbind	2
139/tcp	NetBIOS-SSN	Samba 3.X–4.X
445/tcp	Microsoft-DS	Samba 3.X–4.X
512/tcp	exec	netkit-rsh rexecd
513/tcp	login	OpenBSD/Solaris rlogind
514/tcp	shell	Netkit rshd
1099/tcp	Java RMI	GNU Classpath grmiregistry
1524/tcp	Bindshell	Metasploitable root shell
2049/tcp	NFS	2–4
2121/tcp	FTP	ProFTPD 1.3.1
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5
5432/tcp	PostgreSQL	PostgreSQL 8.3.0–8.3.7
5900/tcp	VNC	VNC Protocol 3.3
6000/tcp	X11	Access denied
6667/tcp	IRC	UnrealIRCd
8009/tcp	AJP13	Apache Jserv
8180/tcp	HTTP	Apache Tomcat/Coyote JSP engine 1.1

Banner Grabbing

The FTP service running on port 21 was tested using Nmap banner grabbing.

Command:

```
nmap -sV --script=banner -p 21 192.168.56.101
```



```
(kali@kali)-[~]
└─$ nmap -sV --script=banner -p 21 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 14:06 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.00044s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ banner: 220 (vsFTPd 2.3.4)
MAC Address: 08:00:27:83:F2:D2 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.56 seconds

(kali@kali)-[~]
```

Figure: Nmap banner grabbing of FTP service on port 21.

Result:

The banner revealed that the target is running **vsftpd 2.3.4** on **FTP port 21**.

Captured Banner:

220 (vsFTPd 2.3.4)

Q10 Web Service Enumeration

Step 1: Verify Web Service

Action:

The target IP address was opened in a web browser using:

<http://192.168.56.101>

Observation:

The Metasploitable2 web page loaded successfully. The page displayed links to **TWiki**, **phpMyAdmin**, **Mutillidae**, **DVWA**, and **WebDAV**.

Evidence:

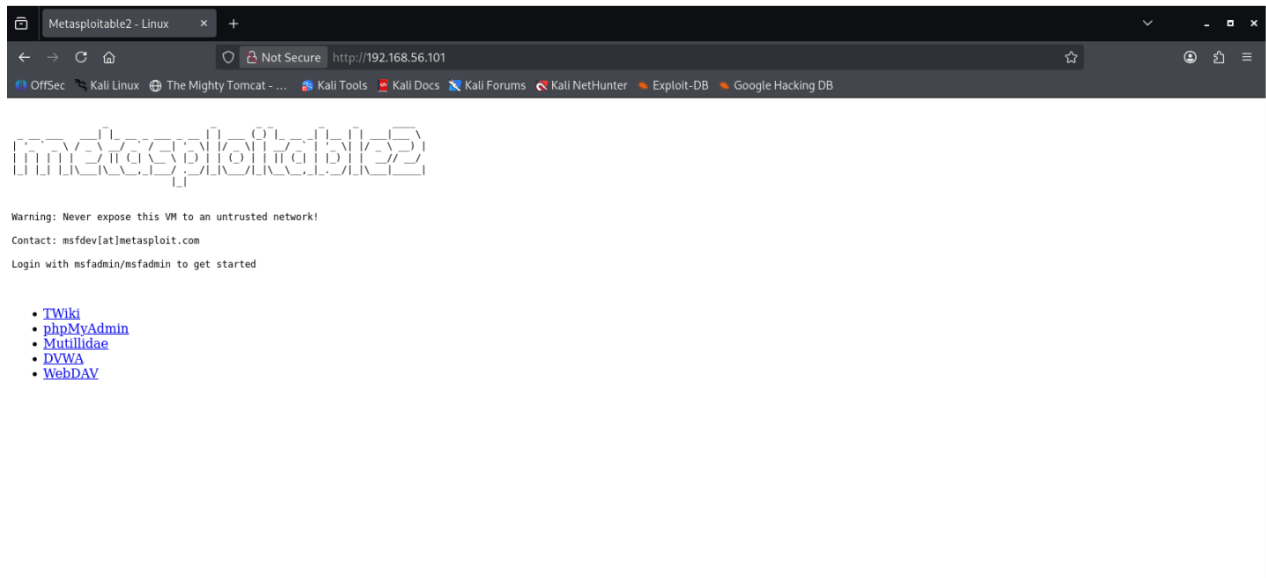


Figure 1: Browser showing the Metasploitable2 web page.

Step 2: HTTP Service Enumeration

Command:

```
nmap -sV --script=http-title,http-headers -p 80 192.168.56.101
```

Key Findings:

Item	Result
Port	80/tcp
Service	HTTP
Web Server	Apache httpd 2.2.8 (Ubuntu) DAV/2)
PHP Version	5.2.4-2ubuntu5.10
HTTP Title	Metasploitable2 - Linux
Content Type	text/html

Evidence:

```
(kali@kali)-[~]
$ nmap -sV --script=http-title,http-headers -p 80 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 14:22 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.00060s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-headers:
|   Date: Thu, 20 Aug 2026 18:22:18 GMT
|   Server: Apache/2.2.8 (Ubuntu) DAV/2
|   X-Powered-By: PHP/5.2.4-2ubuntu5.10
|   Connection: close
|   Content-Type: text/html
|_
|_ (Request type: HEAD)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
MAC Address: 08:00:27:83:F2:D2 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.22 seconds

(kali@kali)-[~]
```

Figure 2: Terminal output of the Nmap HTTP enumeration.

Result:

Nmap enumeration confirmed that the target is running an **Apache HTTP web server on port 80**. The HTTP response headers also revealed the Apache and PHP versions.

Step 3: HTTP Content Enumeration

Command:

```
nmap --script=http-enum -p 80 192.168.56.101
```

```
(kali@kali)-[~]
$ nmap --script=http-enum -p 80 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 14:34 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.00051s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_ http-enum:
|   /tikiwiki/: TikiWiki
|   /test/: Test page
|   /phpinfo.php: Possible information file
|   /phpMyAdmin/: phpMyAdmin
|   /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|   /icons/: Potentially interesting folder w/ directory listing
|_ /index/: Potentially interesting folder
MAC Address: 08:00:27:83:F2:D2 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 3.82 seconds

(kali@kali)-[~]
```

Findings:

Path	Finding
/tikiwiki/	TikiWiki
/test/	Test page
/phpinfo.php	Possible information file
/phpMyAdmin/	phpMyAdmin
/doc/	Potentially interesting directory with listing enabled
/icons/	Potentially interesting folder with directory listing

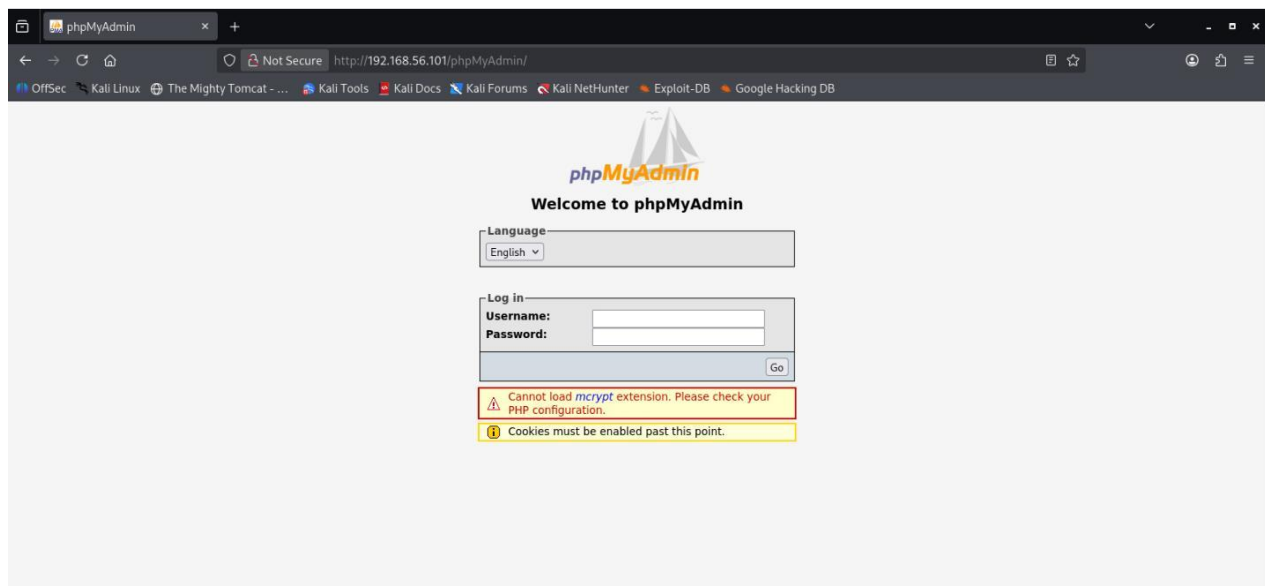
/index/	Potentially interesting folder
---------	--------------------------------

Result:

The HTTP enumeration identified several accessible and potentially interesting web resources on the target. These included TikiWiki, phpMyAdmin, a PHP information file, a test page, and directories with possible directory listing enabled.

Step 4: Verify phpMyAdmin

The http-enum scan identified the /phpMyAdmin/ directory on the target. I manually accessed the directory through the browser and confirmed that the phpMyAdmin login page was available.



Observed:

- URL: http://192.168.56.101/phpMyAdmin/
- Service: phpMyAdmin
- Login page: Accessible
- Additional warnings: mcrypt extension and cookie-related warnings were displayed.

Step 5: Relevant OWASP Top 10 Categories

OWASP Category	Relevance / Evidence
A05 – Security Misconfiguration	Directory listing was identified on /doc/ and /icons/, indicating potentially exposed web-server content.
A01 – Broken Access Control	Application-related resources such as /phpMyAdmin/ are publicly reachable and should be reviewed for proper access restrictions.
A06 – Vulnerable and Outdated Components	The identified Apache and PHP versions are outdated components that should be reviewed for known security vulnerabilities.

Step 6: Conclusion

The web-service assessment identified an Apache-based web server running on Ubuntu with PHP support. Several web applications and directories, including TikiWiki and phpMyAdmin, were discovered. Potential security concerns include security misconfiguration, exposed application resources, and outdated software components. No exploitation was performed during this assessment.

Phase :04 Vulnerability Assessment

Assessment Methodology

Building on the Phase 3 enumeration results, this phase converts each discovered service/version into a documented vulnerability with a real CVE reference, a justified CVSS severity rating, and a place on a Likelihood x Impact risk matrix. The workflow below was followed for every finding in this report.



Figure 1. Phase 4 vulnerability assessment workflow.

Q11. Service/Version → CVE Matching

Using the Nmap service-version results from Phase 3 (Q9), the following services were cross-referenced against the NVD to identify known, publicly documented vulnerabilities. Four findings with clear, well-documented CVEs were selected, spanning FTP, IRC, SMB, and HTTP.

#	Port / Service	Version Detected	CVE ID	Vulnerability
F1	21/tcp — FTP	vsftpd 2.3.4	CVE-2011-2523	Malicious backdoor opens a root shell on port 6200/tcp
F2	6667/tcp — IRC	UnrealIRCd 3.2.8.1	CVE-2010-2075	Trojanized source code allows remote arbitrary command execution
F3	139,445/tcp — SMB	Samba 3.X ("username map script")	CVE-2007-2447	Shell metacharacters in username map script allow remote command execution
F4	80/tcp — HTTP	Apache httpd 2.2.8	CVE-2011-3192	Overlapping byte-range requests cause memory/CPU exhaustion (DoS)

- **F1 — vsftpd 2.3.4 Backdoor (CVE-2011-2523)**

vsftpd 2.3.4, as distributed between 30 June and 3 July 2011, contains a malicious backdoor. A username ending in the sequence "*)" triggers the server to open a root-level command shell on TCP port 6200, giving an unauthenticated attacker full control of the host.

- **F2 — UnrealIRCd Trojaned Source (CVE-2010-2075)**

Copies of UnrealIRCd 3.2.8.1 distributed on certain mirrors between November 2009 and June 2010 contained a Trojan-horse modification in the DEBUG3_DOLOG_SYSTEM macro. Any string sent to the IRC listener beginning with "AB;" is passed to a system() call, giving remote attackers command execution as the service account.

- **F3 — Samba "username map script" RCE (CVE-2007-2447)**

Samba 3.0.0 through 3.0.25rc3 allows remote command execution via shell metacharacters passed through the non-default "username map script" smb.conf option. Because usernames are processed before authentication, no valid credentials are required to exploit it.

- **F4 — Apache HTTP Server Byte-Range DoS (CVE-2011-3192)**

The byte-range filter in Apache HTTP Server versions prior to 2.2.20 mishandles HTTP requests containing many overlapping Range headers, allowing a remote, unauthenticated attacker to exhaust server memory and CPU and cause a denial of service.

Q12. CVSS Severity Ratings & Justification

Each finding was scored using CVSS v3.x base metrics, sourced from NVD and corroborating vendor advisories. Scores reflect that all four services are directly reachable over the network with no authentication or user interaction required.

CVSS Severity Comparison — Discovered Vulnerabilities

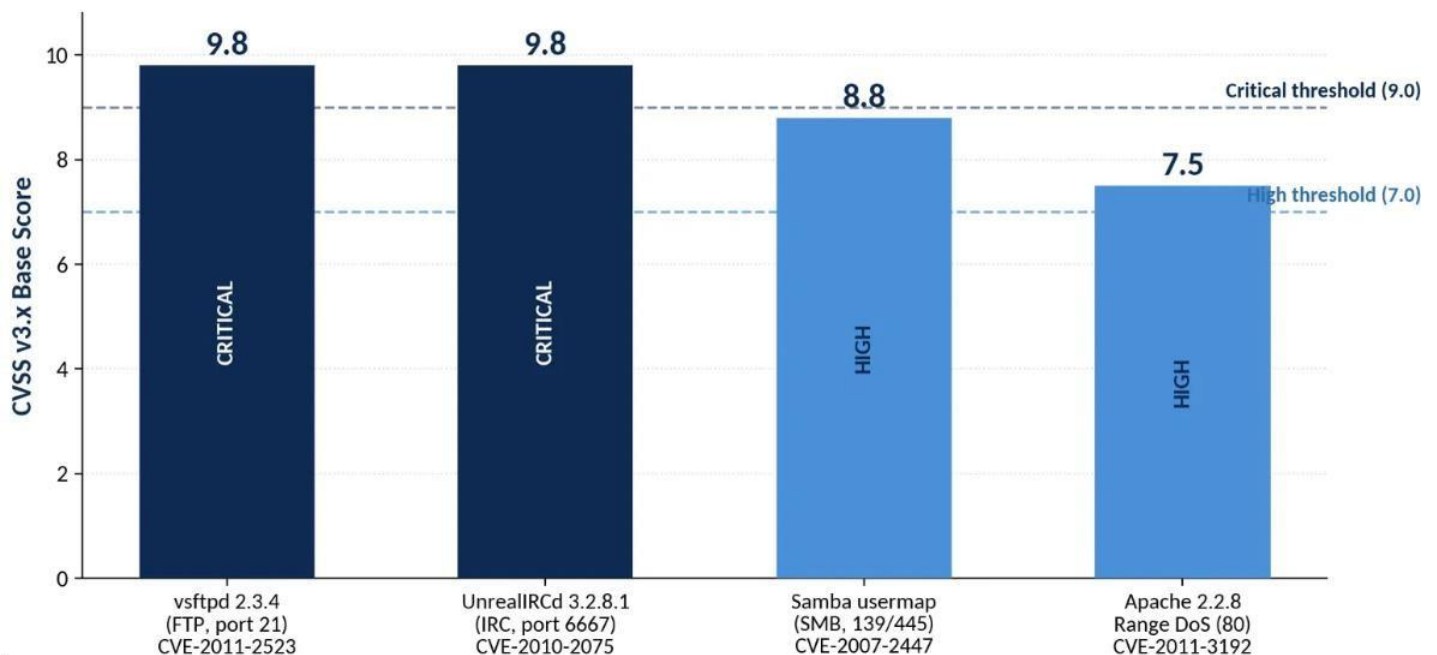
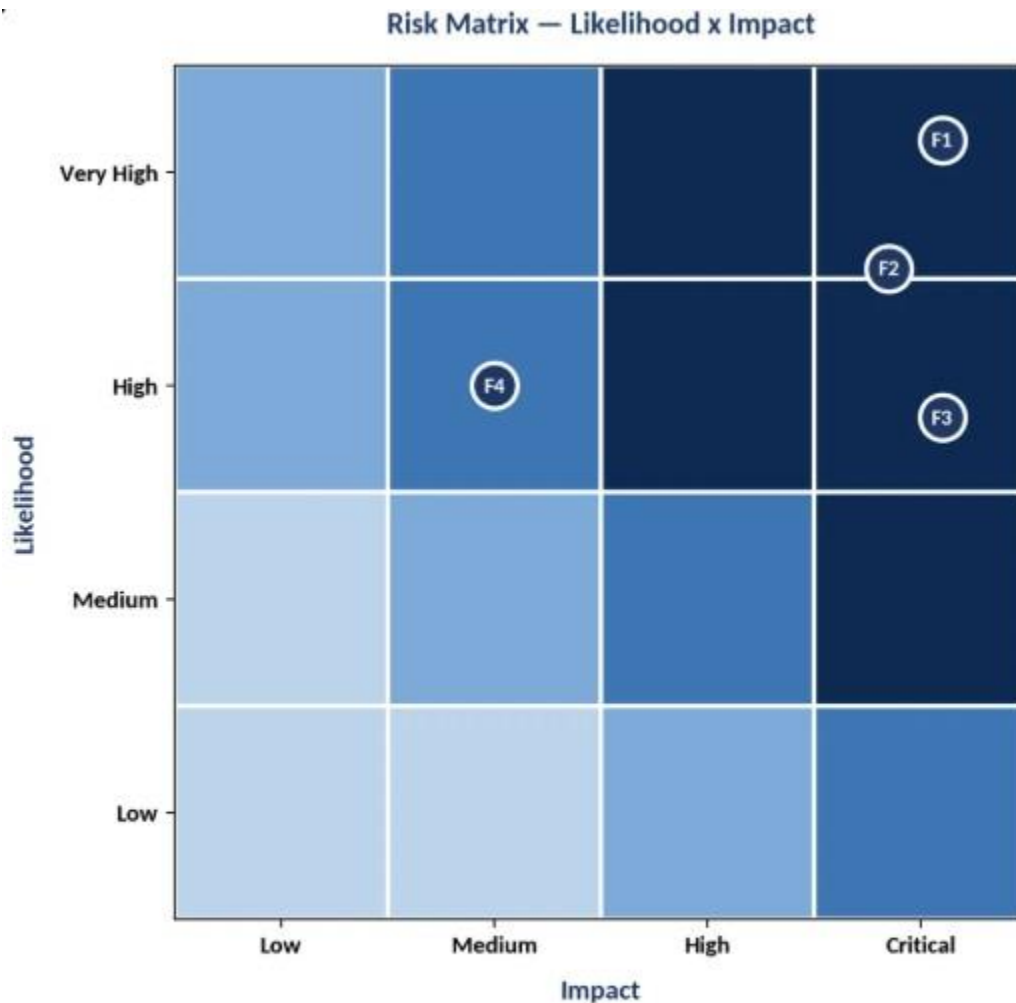


Figure 2. CVSS v3.x base scores for the four matched vulnerabilities.

Finding	CVSS v3.x	Vector	Justification
F1 — vsftpd	9.8 CRITICAL	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Network-exploitable, low complexity, no privileges or user interaction needed; a successful trigger yields a root shell — full compromise of confidentiality, integrity, and availability.
F2 — UnrealIRCd	9.8* CRITICAL	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Same profile as F1: unauthenticated, network-reachable command execution. NVD's original CVSSv2 score was 7.5 (High); the widely cited CVSSv3 re-assessment is 9.8 (Critical) given full remote code execution.
F3 — Samba	8.8 HIGH	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Network-exploitable with low complexity and no authentication (usernames are mapped pre-auth); scored High rather than Critical mainly due to reliance on the non-default "username map script" option being enabled.
F4 — Apache DoS	7.5 HIGH	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	Trivially reachable over the network with public exploit tools, but impact is limited to availability (service outage) — confidentiality and integrity are not affected, keeping it below Critical.

Q13. Risk Matrix (Likelihood x Impact)

Likelihood reflects how easy and reliable exploitation is (public Metasploit modules, authentication required, complexity). Impact reflects the worst-case consequence (from service disruption up to full root compromise).



F1 = vsftpd 2.3.4 Backdoor (CVE-2011-2523) F2 = UnrealIRCd Trojan Backdoor (CVE-2010-2075)
 F3 = Samba userman <print RCF (CVE-2007-2447) F4 = Apache Range-Header DoS (CVE-2011-3192)

Figure 3. Risk placement of all four findings.

Finding	Likelihood	Impact	Risk Level
F1 — vsftpd backdoor (CVE-2011-2523)	Very High	Critical	CRITICAL
F2 — UnrealIRCd backdoor (CVE-2010-2075)	Very High	Critical	CRITICAL
F3 — Samba usermap RCE (CVE-2007-2447)	High	Critical	CRITICAL
F4 — Apache Range-header DoS (CVE-2011-3192)	High	Medium	HIGH

Three of the four findings land in the Critical risk band: each has a public, no-authentication exploit path that leads directly to root-level command execution. F4 is rated High rather than Critical because its worst-case outcome is a denial of service, not a compromise of data or system control. Remediation priority should therefore be F1, F2, and F3 first, followed by F4.

Q14. HTTPS/TLS Evaluation & Encryption Concepts

- **Finding: No HTTPS/TLS on the Target**

The Phase 3 web enumeration (Q10) found the target's web application reachable only over plain HTTP on port 80 (Apache httpd 2.2.8). No service was found listening on port 443, and no TLS/SSL certificate was observed in any scan. This means all web traffic to and from the target — including any form submissions, session cookies, or phpMyAdmin login attempts — travels in plaintext and can be read or modified by anyone able to observe the network path (e.g., via ARP spoofing or a shared segment).

- Recommendation: terminate HTTP entirely, deploy TLS 1.2+ with a valid certificate on port 443, and redirect all port 80 traffic to HTTPS.

- **Symmetric vs. Asymmetric Encryption**

Symmetric encryption uses a single shared secret key for both encrypting and decrypting data. It is fast and efficient, which makes it well suited to encrypting large volumes of traffic — but the key must somehow be shared between both parties in advance without being intercepted. Common example: AES.

Asymmetric encryption uses a mathematically linked key pair: a public key that can be shared openly, and a private key that must stay secret. Data encrypted with the public key can only be decrypted with the matching private key. It solves the key-distribution problem but is computationally heavier, so it is used sparingly. Common example: RSA.

Target Assessment: Plain HTTP on Port 80 (No TLS Observed)



How TLS Uses Both Encryption Types



Figure 4. Current plaintext HTTP state vs. recommended HTTPS/TLS state, and how TLS combines both encryption types.

- In practice, TLS (the protocol behind HTTPS) uses both: it starts with an asymmetric handshake to authenticate the server via its certificate and safely agree on a one-time shared secret, then switches to fast symmetric encryption (e.g., AES-256-GCM) to protect the actual data for the rest of the session. This gives the security of asymmetric key exchange with the performance of symmetric bulk encryption.

Q15. Incident Response Plan — Critical Vulnerability Exploited, Customer Data Stolen

Scenario: The vsftpd 2.3.4 backdoor (F1, CVE-2011-2523, CVSS 9.8 Critical) was exploited by an external attacker, who obtained a root shell and exfiltrated a customer database from the host. The plan below follows the Detect → Contain → Eradicate → Recover model.

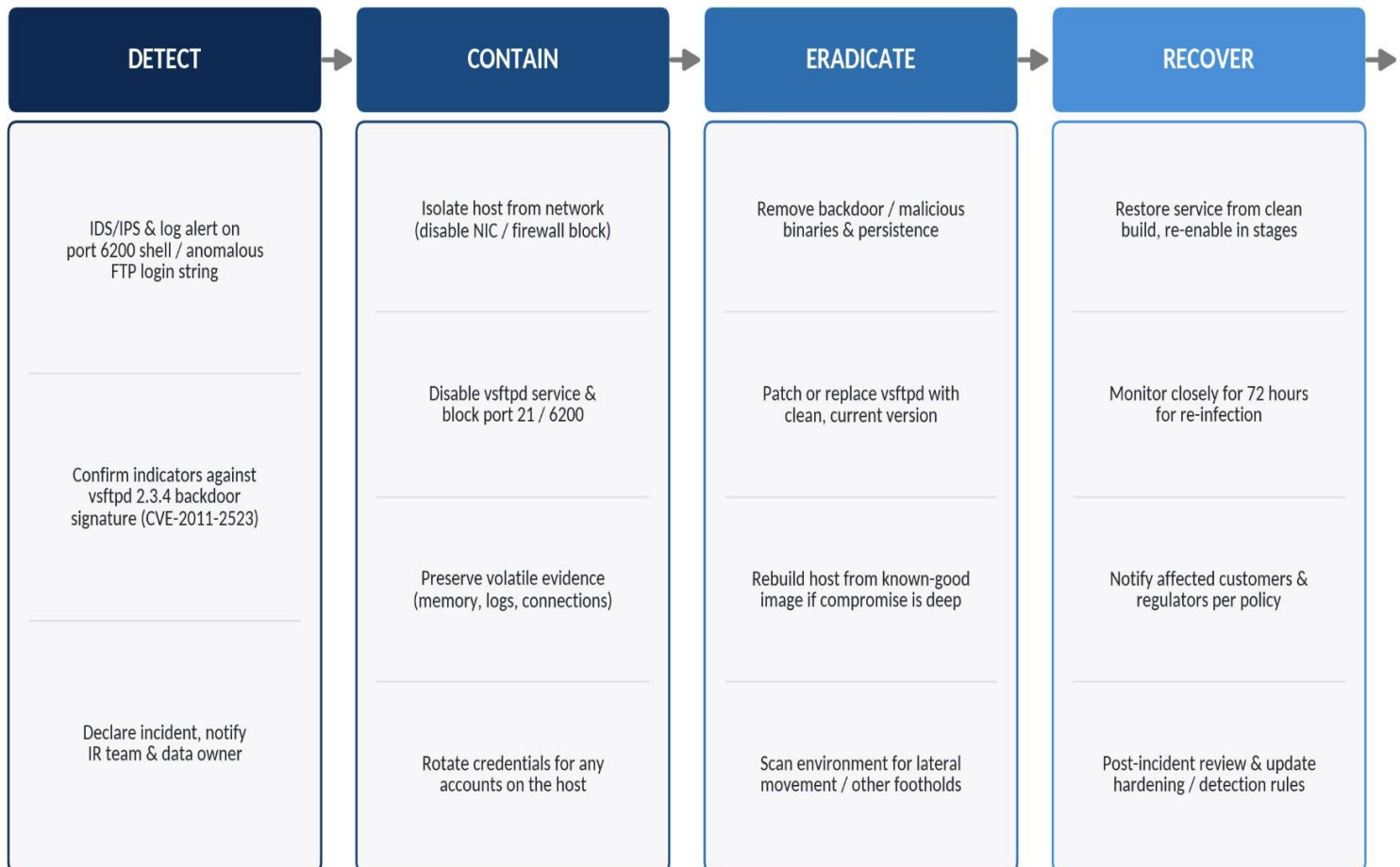


Figure 5. Incident response workflow for the vsftpd backdoor scenario.

Detect

- Trigger: IDS/log alert on an unexpected listener/shell on TCP port 6200, or an FTP login attempt containing the "*)" trigger string in server logs.
- Validate the indicator against the known vsftpd 2.3.4 backdoor signature (CVE-2011-2523) to rule out a false positive.
- Declare a formal incident, assign an incident commander, and notify the IR team, system owner, and data-protection/legal contact given customer data is involved.

Contain

- Immediately isolate the affected host from the network (disable the interface or apply an emergency firewall rule) to stop further data exfiltration.
- Disable the vsftpd service and block inbound/outbound traffic on ports 21 and 6200 at the perimeter firewall.
- Preserve volatile evidence before shutdown: running processes, network connections, memory image, and relevant logs, for forensic analysis and any legal/regulatory follow-up.
- Rotate credentials for any accounts that were reachable from, or stored on, the compromised host.

Eradicate

- Remove the backdoor and any attacker-planted tools, scripts, or persistence mechanisms (cron jobs, added SSH keys, new user accounts).
- Patch or replace vsftpd with a current, non-backdoored release; verify package integrity via checksums going forward.
- If the depth of compromise is uncertain (root access was obtained), rebuild the host from a known-good, patched image rather than trusting a cleaned system.
- Scan the wider environment for lateral movement or additional footholds using the same credentials/techniques.

Recover

- Restore the service from the clean build and re-enable it in stages, with heightened monitoring at each step.
- Monitor closely for 72 hours for signs of re-infection or renewed attacker activity.
- Notify affected customers and relevant regulators of the data breach in line with legal obligations and organizational policy (e.g., breach-notification timelines).
- Conduct a post-incident review: update detection rules for this signature, patch/inventory management, and harden FTP/service exposure to prevent recurrence.